Health Information Trust Alliance (HITRUST) Common Security Framework (CSF)

HITRUST CSF overview

The Health Information Trust Alliance (HITRUST) is an organization governed by representatives from the healthcare industry. HITRUST created and maintains the Common Security Framework (CSF), a certifiable framework that helps healthcare organizations and their providers demonstrate their security and compliance in a consistent and streamlined manner.

The CSF builds on HIPAA and the HITECH Act, which are US healthcare laws that establish requirements for the use, disclosure, and safeguarding of individually identifiable health information, and that enforce noncompliance. HITRUST provides a benchmark - a standardized compliance framework, assessment, and certification process - against which cloud service providers and covered health entities can measure compliance. The CSF also incorporates healthcare-specific security, privacy, and other regulatory requirements from such existing frameworks as the Payment Card Industry Data Security Standard (PCI-DSS), ISO/IEC 27001 information security management standards, and Minimum Acceptable Risk Standards for Exchanges (MARS-E).

The CSF is divided into 19 different domains, including endpoint protection, mobile device security, and access control. HITRUST certifies IT offerings against these controls. HITRUST also adapts requirements for certification to the risks of an organization based on organizational, system, and regulatory factors.

Health Information Trust Alliance (HITRUST) Common Security Framework (CSF)

HITRUST offers three degrees of assurance, or levels of assessment: self-assessment, CSF validated, and CSF-certified. Each level builds with increasing rigor on the one below it. An organization with the highest level, CSF-certified, meets all the certification requirements of the CSF. Microsoft Azure and Office 365 are the first hyperscale cloud services to receive certification for the HITRUST CSF. Coalfire, a HITRUST assessor firm, performed the assessments based on how Azure and Office 365 implement security, privacy, and regulatory requirements to protect sensitive information. Microsoft supports the HITRUST Shared Responsibility Program.

Learn how to accelerate your HITRUST deployment with our Azure Security and Compliance Blueprint.

Download the Microsoft Azure HITRUST Customer Responsibility Matrix (CRM) blueprint v9.0d

Microsoft in-scope cloud platforms and services

- Azure and Azure Government
- Microsoft Intune
- Microsoft Managed Desktop
- Office 365
- Windows 365 (Commercial)

Azure, Microsoft Dynamics 365, and HITRUST

For more information about Azure, Dynamics 365, and other online services compliance, see the Azure HITRUST offering.

Office 365 and HITRUST

Office 365 environments

Microsoft Office 365 is a multi-tenant hyperscale cloud platform and an integrated experience of apps and services available to customers in several regions worldwide. Most Office 365 services enable customers to specify the region where their customer data is located. Microsoft may replicate customer data to other regions within the same geographic area (for example, the United States) for data resiliency, but Microsoft will not replicate customer data outside the chosen geographic area.

This section covers the following Office 365 environments:

- **Client software (Client)**: commercial client software running on customer devices.
- **Office 365 (Commercial)**: the commercial public Office 365 cloud service available globally.
- **Office 365 Government Community Cloud (GCC)**: the Office 365 GCC cloud service is available for United States Federal, State, Local, and Tribal governments, and contractors holding or processing data on behalf of the US Government.
- **Office 365 Government Community Cloud - High (GCC High)**: the Office 365 GCC High cloud service is designed according to Department of Defense (DoD) Security Requirements Guidelines Level 4 controls and supports strictly regulated federal and defense information. This environment is used by federal agencies, the Defense Industrial Base (DIBs), and government contractors.
- **Office 365 DoD (DoD)**: the Office 365 DoD cloud service is designed according to DoD Security Requirements Guidelines Level 5 controls and supports strict federal and defense regulations. This environment is for the exclusive use by the US Department of Defense.

Use this section to help meet your compliance obligations across regulated industries and global markets. To find out which services are available in which regions, see the International availability information and the Where your Microsoft 365 customer data is stored article. For more information about Office 365 Government cloud environment, see the Office 365 Government Cloud article.

Your organization is wholly responsible for ensuring compliance with all applicable laws and regulations. Information provided in this section does not constitute legal advice and you should consult legal advisors for any questions regarding regulatory compliance for your organization.

Office 365 applicability and in-scope services

Use the following table to determine applicability for your Office 365 services and subscription:

Expand table

Applicability	In-scope services
Commercial	Activity Feed Service, Bing Services, Delve, Exchange Online Protection, Exchange Online, Microsoft Teams, Office 365 Customer Portal, Office Online, Office Service Infrastructure, Office Usage Reports, OneDrive for Business, People Card, SharePoint Online, Windows Ink

Office 365 audits, reports, and certificates

The HITRUST CSF certification of Office 365 is valid for two years.

- Office 365 HITRUST Letter of Certification

Frequently asked questions

Why are some Office 365 services not in the scope of this certification?

Microsoft provides the most comprehensive offerings compared to other cloud service providers. To keep up with our broad compliance offerings across regions and industries, we include services in the scope of our assurance efforts based on market demand, customer feedback, and product lifecycle. If a service isn't included in the current scope of a specific compliance offering, your organization is responsible for assessing the risks based on your compliance obligations and determining how you process the data in that service. We continuously collect feedback from customers and work with regulators and auditors to expand our compliance coverage to meet your security and compliance needs.

Does Microsoft certification mean that if my organization uses Office 365, it is compliant with HITRUST CSF?

When you store your data in a SaaS like Office 365, it's a shared responsibility between Microsoft and your organization to achieve compliance. Microsoft manages most of the infrastructure controls, including physical security, network controls, and application-level controls. Your organization is responsible for managing access controls and protecting your sensitive data. The Office 365 HITRUST certification demonstrates the compliance of Microsoft's control framework. Building on that framework, your organization needs to implement and maintain its own data protection controls to meet HITRUST CSF requirements.

Does Microsoft provide guidance for my organization to implement appropriate controls when using Office 365?

Yes, you can find recommended customer actions in Compliance Manager, cross-Microsoft Cloud solutions that help your organization meet complex compliance obligations when using cloud services. Specifically, for HITRUST CSF, we recommend that you perform risk assessments using the NIST 800-53 and NIST CSF assessments in Compliance Manager. In the assessments, we provide you with step-by-step guidance and the Microsoft solutions you can use to implement your data protection controls. You can learn more about Compliance Manager in Microsoft Purview Compliance Manager.

Use Microsoft Purview Compliance Manager to assess your risk

Microsoft Purview Compliance Manager is a feature in the Microsoft Purview portal to help you understand your organization's compliance posture and take actions to help reduce risks. Compliance Manager offers a premium template for building an assessment for this regulation. Find the template in the **assessment templates** page in Compliance Manager. Learn how to build assessments in Compliance Manager.

Resources

- HITRUST Alliance
- HITRUST CSF 9.5
- Understanding and Leveraging the CSF
- Compliance on the Microsoft Trust Center

Last updated on 12/04/2025